KAVACH

Pre-execution action firewall for AI agents

Before an agent acts, make the consequence visible.

SAFE / AUTHORIZED / EXPLAINABLE / REVERSIBLE

ET-03 · Agentic AI Guardrail Validator · Qualcomm Cloud AI

EVIDENCE README.md; kavach/gateway.py; THREAT_MODEL.md

Project context & delivery scope

A working guardrail, an operator console, and evidence for each claim.

Who uses it

Agent owners integrate tools.

AP and finance reviewers approve exceptions.

Auditors inspect decision evidence.

What is delivered

FastAPI gateway + web console

MCP proxy + SDK adapters

Demo services + evaluation harness

Where it fits

Infosys agent workflows

Email, CRM, files and payments

Qualcomm-hosted agent and advisory judge

Submission focus: action input → decision → explanation, with enforceable execution controls.

EVIDENCE README.md; PRODUCT.md; RELEASE_ACCEPTANCE.md; integrations/

Problem Statement

An agent can turn untrusted content into an unauthorized real-world action.

01 Data leaves

User asks for a summary.

An email asks for the customer list.

The agent proposes an external send.

02 Money redirects

Invoice names a vendor.

A message supplies new bank details.

The agent proposes the wrong account.

03 Scope expands

User names one record.

The agent writes many rows or a sensitive field.

A tool allowlist cannot explain the impact.

Success = the right task completes, unauthorized calls stop, and the receipt explains the actual outcome.

EVIDENCE THREAT_MODEL.md; tests/test_trace.py; tests/test_invoice_demo.py

Proposed Solution

Check intent, authority, argument origin and impact at the tool boundary.

INPUT

Trusted request
Tool + arguments
Identity + prior outputs

›

CHECK

Provenance + impact
Policy rules
Intent + risk signal

›

DECIDE

Allow
Allow with safeguard
Escalate / deny

›

PROVE

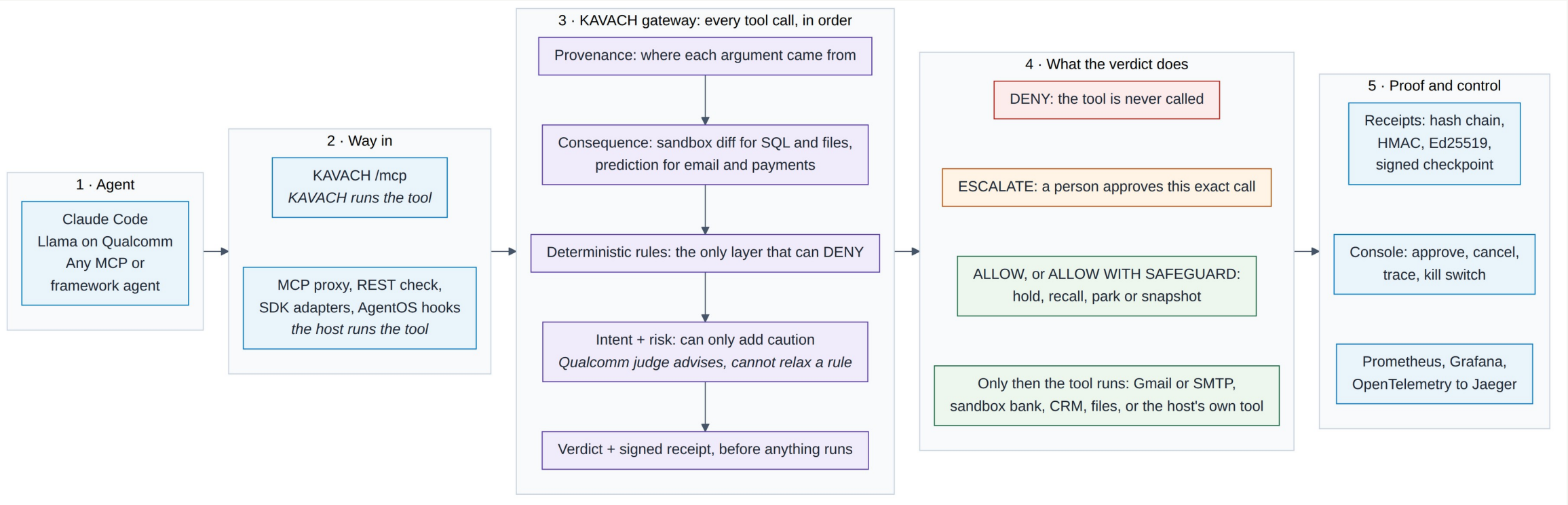
Receipt + source trail
Connector outcome
Undo status

Own synthetic suite: 95.2% safe auto-completion; 0.0% unsafe auto-allowed (five-seed mean).

EVIDENCE kavach/gateway.py; policy.py; bench/results/multiseed.json

Architecture & Technical Design

One decision engine; execution guarantees depend on the integration path.



Python · FastAPI · vanilla JavaScript · YAML policy · NumPy / scikit-learn · optional MCP and crypto extras

EVIDENCE kavach/server.py; gateway.py; environment.py; mcp_proxy/proxy.py; store.py

AI Usage & Innovation

AI assists semantic review; deterministic controls carry the safety boundary.

Deterministic core

Argument origin + business facts

Policy cannot be relaxed by AI.

Unknown or changed tools fail closed.

Qualcomm assistance

Default: note on escalations

Live inline test: 7/12 misreadings caught; heuristic: 1/12

Safe rewordings: 11/12 in both

Measured limits

Risk-zero ablation: no verdict changes on the suite

LLM rewrites are optional.

Models never override a denial.

Differentiator: argument lineage + measured or predicted impact + exact-action approval + effect evidence.

EVIDENCE kavach/gateway.py; intent.py; explain.py; bench/results/layers.json; semantic.json

Readiness, Scalability & Security

Demo-ready for documented workflows; production work remains.

Implemented

Exact-action approvals + kill switch

Durable holds + delivery recovery

Signed receipts + checkpoint

Verified here

521 tests passed

14 optional tests skipped

External benchmarks reported as saved runs

Next engineering work

CI, load + backup/restore drills

Alertmanager delivery

Wider attacks + remaining benchmark runs

Deployment constraint: one receipt-chain writer; no measured multi-replica scaling claim.

EVIDENCE RELEASE_ACCEPTANCE.md; docs/DEPLOY.md; profile.py; deploy/helm/kavach/; tests/

Demo: prove what actually happened

Use the inbox, bank ledger and trace beside the agent's explanation.

Story	Action	Independent proof
Legitimate email	Queue → deliver or cancel	Mailpit message / empty inbox
Poisoned email	Trace destination → refuse	Trace: connector never called
Invoice substitution	Account check → human approval	Sandbox bank: approved payee only
Recovery / pause	Restart with a queued action; pause	No duplicate send; waiting action cancelled

REAL = live agent · SCRIPTED = chosen calls · REPLAY = saved run. Identify each on stage.

EVIDENCE DEMO.md; docs/LIVE_DEMO.md; tests/test_trace.py; bench/results/CLAUDE_WITH_WITHOUT.md

Decision path: from call to effect

A decision, an execution, and a delivery outcome are separate facts.

1 CONTEXT

Session + identity
Registered outputs

›

2 EVALUATE

Tool pin + schema
Lineage + consequence

›

3 RECORD

Policy + intent / risk
Receipt before action

›

4 ACT

Execute / wait / refuse
Outcome + trace

Verdict	Meaning
ALLOW	Permitted; no KAVACH undo implied
ALLOW_WITH_SAFEGUARD	Local execution with an armed snapshot, hold or parking
ESCALATE / DENY	Waiting for a person / refused before connector

EVIDENCE kavach/gateway.py: check, execute, resolve_hitl, settle; receipts.py

Provenance & policy: what is trusted

Business records supply facts. Emails and web content do not supply authority.

Control group	Enforced purpose
Origin + destination	Untrusted text cannot grant permission.
Data + workspace	Limit leakage, credential access and path escape.
Business facts	Use invoice / vendor records and approval tiers.
Tool + task controls	Pins, schema, roles, delegation and task totals.

Example: an account in a vendor email stays untrusted; a separate rule checks the account on record.

EVIDENCE kavach/provenance.py; policy.py; policies/default.yaml; tests/

Consequences & the real limits of undo

The deck names the safeguard and who actually arms it.

Operation	Impact evidence	Owned-execution safeguard
SQL / supported files	Sandbox diff	Snapshot / row-level restoration
Email	Typed prediction	Cancel while queued, before delivery
Payment	Prediction + invoice / vendor facts	Hold; recheck account and amount at release
SAP demo / refund	Typed prediction	Park document / no generic refund undo
External proxy / hook	Manifest + available context	Host executes; no KAVACH-owned undo

The API exposes safeguard_armed. “Allowed” alone does not establish reversibility.

EVIDENCE kavach/consequence.py; environment.py; gateway.py:_allow; tests/test_email_window.py

Human approval is bound to the exact call

Approve a specific task, tool and argument set; changed calls need a new decision.

Before approval

See the effect + source trail.

Verify task + tool + arguments.

Identify the required review roles.

At approval

Use the stored action digest.

Enforce quorum and distinct people.

Expire or deny unattended requests.

Before effect

Changed arguments need a new check.

Approved call is used once.

Settlement rechecks payment facts.

A human approval is a scoped authorization, not permission for future calls in the task.

EVIDENCE kavach/gateway.py:action_digest, resolve_hitl; hitl.py; tests/test_approval_binding.py

Delivery, crash recovery & the kill switch

Failure handling is part of execution, rather than a promise on the approval card.

Store fails first

Pre-action receipt rejected

No connector call

Readiness reports degraded state

Send interrupted

Outcome may be unknown.

Keep the evidence.

Never blindly resend the email.

Operator pauses

Block new calls in scope.

Cancel waiting effects.

Persist the pause across restart.

Guarantee scope: controlled connectors and persisted state; no universal exactly-once delivery claim.

EVIDENCE kavach/environment.py; windows.py; receipts.py; tests/test_kill_queued.py; test_receipt_store_down.py

Identity, receipts & verifiable evidence

Authentication establishes authority; cryptography makes later tampering detectable.

IDENTITY

Signed caller + role
Tenant + task scope

›

RECEIPT

Decision + rule + source
Hash chain + HMAC

›

VERIFICATION

Ed25519 public key
Separate signed checkpoint

Without an auth secret, callers are unauthenticated. Production profile requires real keys.

EVIDENCE kavach/auth.py; identity.py; receipts.py; signing.py; store.py; evidence.py

Integrations & who owns execution

One engine can guard several frameworks, with different operational guarantees.

Path	Executor	Guarantee boundary
Demo MCP / local gateway	KAVACH connectors	Local holds, snapshots, trace and receipts
MCP proxy: stdio / HTTP	Upstream MCP server	Tool scan, pins, decisions; external undo not claimed
REST check (default) / SDK adapters	External tool host	Decision only; host executes + registers outputs
Topaz AgentOS hooks	AgentOS kernel	Governance-code test; LLM chat remains unverified

Deployment requirement: route every relevant tool through the guard and remove direct bypass access.

EVIDENCE kavach/adapters/; mcp_proxy/; integrations/agentos_hook.py; bench/results/AGENTOS_LIVE.md

How Qualcomm Cloud AI is used

The protected agent and the advisory judge have separate jobs.

Role	Configuration	Observed behavior
Protected agent	Llama-3.3-70B	Task + outputs → proposed tools
Advisory judge	Small → strong model; cached	Request + action + labels → reviewer note
Explanation rewrite	Optional; disabled by default	19/47 kept; 22 rejected; 6 unavailable
Failure path	Deterministic fallback	Cannot relax policy denial or approval floor

Usage meter records returned tokens; unrecorded benchmark cost stays unknown, not zero.

EVIDENCE kavach/qualcomm.py; intent.py; explain.py; agent/llm_agent.py; bench/results/explain.json

Synthetic evaluation: what was measured

Team-written suite: regression evidence, with a stated test split and denominators.

System	Unsafe allowed	Injection ASR	Safe auto	Escalated
No guardrail	100.0%	100.0%	100.0%	0.0%
Tool-type gating	38.5%	25.0%	47.6%	57.5%
Approve every write	3.9%	0.0%	9.5%	93.6%
KAVACH: rules only	3.9%	0.0%	95.2%	24.8%
KAVACH: full	0.0%	0.0%	95.2%	26.9%

940 scenarios · 47 families · 5 seeds · undo armed for 94.4% of auto-completed changes

EVIDENCE bench/results/results.json; multiseed.json; RESULTS.md

Ablations: which layers earn the result?

The strongest finding is the deterministic core, not the risk-model headline.

Change	Saved observation	Implication
Force model risk to zero	No verdict changes	Rules + intent gate decide this suite.
Use model only	69.2% unsafe allowed	A learned score cannot replace policy.
Remove provenance	12.5% injection ASR	Lineage adds measured protection.
Use a fixed threshold	Same aggregate metrics as full	Do not claim proven threshold superiority.

Family-level result: 0/26 unsafe families leaked; reported 95% interval reaches 13%.

EVIDENCE bench/results/layers.json; LAYERS.md; LOFO.md; HOLDOUT.md; results.json

Live AgentDojo: banking paired results

Saved partial run on Llama-3.3-70B; raw live-task logs are absent from this checkout.

Defense	Attack success ↓	Benign done	Task done under attack
No guardrail	65/128 (50.8%)	8/16 (50.0%)	53/128 (41.4%)
KAVACH	0/128 (0.0%)	8/16 (50.0%)	62/128 (48.4%)

Paired sample

144 completed task pairs
16 benign + 128 attacked

Evidence scope

144/160 planned tasks completed.
Saved aggregate; not independently rerun.

EVIDENCE bench/results/comparison.json: live.banking.paired.kavach; COMPARISON.md

Live AgentDojo: Slack tradeoffs

Saved paired summary; raw live-task logs unavailable here. Task completion also falls.

Defense	Attack success ↓	Benign done	Task done under attack
No guardrail	48/103 (46.6%)	9/21 (42.9%)	36/103 (35.0%)
KAVACH	11/103 (10.7%)	6/21 (28.6%)	21/103 (20.4%)

124 paired tasks; KAVACH completed 124/126 planned.
Official attack success includes attempted-call scoring for one Slack attack.

EVIDENCE bench/results/comparison.json: live.slack.paired.kavach; COMPARISON.md; AGENTDOJO_REPLAY.md

Replay evidence is a different experiment

Ground-truth tool calls and an obedient attacker; no live model is involved.

Replay suite	Benign done	Official attack success	Executed-only success
Banking	12/16 (+4 escalated)	0/144	0/144
Slack	14/21 (+6 escalated)	21/105	0/105

What this proves

Enforcement on the exact calls
an obedient attacker would request.

What must stay qualified

Different scoring views are shown.
Replay is not live model behavior.

EVIDENCE bench/results/AGENTDOJO_REPLAY.md; agentdojo_replay_banking.json; agentdojo_replay_slack.json

Infosys integration & local baseline evidence

Saved local-harness comparison; the external Infosys deployment was not revalidated here.

Local configuration	Unsafe allowed	Injection ASR	Safe auto	Escalated
AgentOS default gate	96.2%	100.0%	100.0%	0.0%
AgentOS hardened gate	3.9%	0.0%	14.3%	89.4%
Interrupt every change	3.9%	0.0%	9.5%	93.6%
KAVACH	0.0%	0.0%	95.2%	26.6%

These are harness results for named configurations, not a blanket ranking of enterprise products.

EVIDENCE bench/results/infosys_compare.json: seed0; INFOSYS_COMPARISON.md; AGENTOS_LIVE.md

Operator console & observability

Follow the action from request through decision to connector outcome.

Business reviewer

Action checker + consequence card

Approvals + cancel / release

Rulebook + receipt verification

Operator

Trace request → actual effect

Prometheus + Grafana

OpenTelemetry → Jaeger

Evidence and limits

14 alert rules; no Alertmanager delivery

No raw tool args in telemetry

Missing token prices remain unknown

Proof chain: request → call ID → decision → receipt → outbox → SMTP correlation header.

EVIDENCE kavach/static/; server.py; telemetry.py; usage.py; deploy/alerts.yml; deploy/grafana/

Optional capabilities & activation limits

The core runs offline; extras require configuration and their own validation.

Capability	Repository implementation	Maturity boundary
Policy + privacy	Cedar, signed bundles, CPU probe, Presidio	Optional dependencies / flags
Feedback + counterfactual	Retraining gate, MELON, policy replay	On demand; not automatic learning
Typed planner	Reference-labelled plan execution	Offline tested; live plan generation incomplete
Shell + external anchors	Docker dry run; optional public anchoring	No general containment or live-anchor claim

Use the test run’s skips and the release acceptance file to judge which extras were exercised.

EVIDENCE requirements-extra.txt; kavach/cedar_policy.py; planner.py; melon.py; learning.py; pii.py; shell.py

Deployment & remaining work

A secured reference deployment is available; production readiness is unproven.

Run locally

FastAPI + offline console

Optional Qualcomm credentials

SMTP / sandbox bank for demos

Secure the reference

Enable auth + real signing keys.

Configure DB + separate checkpoint.

Remove direct tool bypass routes.

Complete before rollout

CI + sustained load testing

Backup / restore + alert delivery

Broader attacks and utility tuning

Helm uses one replica and Recreate strategy to protect the single-writer receipt chain.

EVIDENCE Dockerfile; docker-compose.yml; deploy/helm/kavach/; docs/DEPLOY.md; RELEASE_ACCEPTANCE.md

Evidence map & presentation takeaways

Every implementation or measurement claim points back to the repository.

Question	Read first
How does an action become an effect?	kavach/gateway.py + environment.py
Why is a call blocked or reviewed?	policy.py + provenance.py + policies/default.yaml
Can we undo and verify it?	consequence.py + receipts.py + store.py
Which numbers are defensible?	bench/results/*.json + named experiment reports

Claim the measured benefit, show the actual effect, and state where human review or further work is needed.

EVIDENCE README.md; RELEASE_ACCEPTANCE.md; THREAT_MODEL.md; bench/results/; tests/

How KAVACH compares

Each approach solves part of the problem. KAVACH combines the checks at the tool call.

Approach (example)	Decides at the tool call	Traces where values came from	Reads the real effect first	Hold or undo before it lands	Approval tied to the exact call	Signed, verifiable receipts
Text scanner (Infosys PromptGuard, RAI proxy)	—	—	—	—	—	—
Prompt + reasoning scanner (Meta LlamaFirewall)	Partly	—	—	—	—	—
Tool name + schema check (NVIDIA NeMo tool rails)	Yes	—	—	—	—	—
Pattern gate + hooks (Infosys AgentOS)	Yes	Partly	—	—	Partly	—
Policy gateway (AWS AgentCore Policy)	Yes	—	—	—	—	—
Least privilege (Progent)	Yes	—	—	—	Partly	—
Information flow (Google CaMeL)	Yes	Yes	—	—	Partly	—
Information flow (Microsoft FIDES)	Yes	Yes	—	—	—	—
KAVACH	Yes	Yes	Yes*	Yes*	Yes*	Yes

* SQL and files are measured in a sandbox; email and payments are predicted. Hold, undo and exact-call approval apply when KAVACH runs the tool. — = not a feature in the paper or docs we read, which doesn't prove it can't be added. Stronger elsewhere: CaMeL and FIDES enforce information flow by design, if the agent runs inside their planner; KAVACH's tracing is value matching, with known limits.

USP: origin of each value + real effect + approval for the exact call + a chance to stop it + a signed record.

EVIDENCE arXiv 2503.18813 (CaMeL); arXiv 2505.23643 (FIDES); arXiv 2504.11703 (Progent); arXiv 2505.03574 (LlamaFirewall); docs.nvidia.com NeMo Guardrails tool-calling page; aws.amazon.com Policy in Bedrock AgentCore; docs/INFOSYS_GAP_ANALYSIS.md

Infosys AgentOS and KAVACH

AgentOS is Infosys's own agent runtime. We read and ran its code. KAVACH plugs into it; it does not replace it.

	Infosys AgentOS (built-in paths we read)	KAVACH
What it looks at	Hooks, tool and skill names, and patterns over commands and arguments	Where each value came from, and what this call would change
Injected email	PromptGuard and the RAI proxy paths don't see tool output; a custom hook could	Output labelled untrusted; an address taken from it is refused
Business limits	approval_rules are evaluated inside a tool the agent must choose to call, on context it supplies	Rules run outside the model; payment facts come from records (demo company today)
Approval card	Durable holds, with a stale-config check; card shows tool, command preview, skill, rule	Effect, each argument's origin, explanation; tied to the exact call
Undo	Holds pause a call; "rollback" means tool-code versions	Hold, recall, park or snapshot when KAVACH runs the tool
Audit log	JSONL and OpenTelemetry; no linked hash chain in the path we read	Hash chain, HMAC, Ed25519, signed checkpoint

Same team-written suite, 282 test cases, seed 0: AgentOS default gate: 96.2% unsafe allowed, 100.0% safe work done, 0.0% sent to a person; AgentOS hardened gate: 3.9% unsafe allowed, 14.3% safe work done, 89.4% sent to a person; KAVACH: 0.0% unsafe allowed, 95.2% safe work done, 26.6% sent to a person.

We plug in, we don't replace. AgentOS keeps routing, sandboxing, approval operations and RBAC, where it is ahead of us; KAVACH joins through its PreToolUse hooks and supplies the judgment. Tested through AgentOS's governance code with a stand-in agent; a full LLM-driven AgentOS chat isn't verified. There AgentOS runs the tool, so KAVACH's hold and undo don't apply.

AgentOS keeps routing, sandboxing, approvals and RBAC. KAVACH supplies the judgment through its hooks.

EVIDENCE docs/INFOSYS_GAP_ANALYSIS.md; bench/results/infosys_compare.json; INFOSYS_COMPARISON.md; AGENTOS_LIVE.md; integrations/agentos_hook.py